PLAN DE IMPLEMENTACIÓN DEL PROGRAMA DE PROTECCIÓN DE DATOS PERSONALES

DELEGADO DE PROTECCIÓN DE DATOS PERSONALES

BANCO DEMO S.A

PPDP-DEMO-01

Versión: 1.0

Fecha de emisión: XX / XX / XXXX

Nota. *Documento elaborado con fines demostrativos. Los nombres de entidades, personas y fechas son referenciales o ficticios.*

CONTROL DE VERSIONES DEL DOCUMENTO

Versión	Fecha	Descripción del cambio	Elaborado por	Aprobado por
1.0	XX/XX/XXXX	Emisión de primera versión de Programa de PDP	Delegado de Protección de Datos	Gerencia

CONTENIDO

1. CONTEXTO Y JUSTIFICACIÓN DEL PLAN DE IMPLEMENTACIÓN DEL PROGRAMA DE PROTECCIÓN DE DATOS PERSONALES 4

2. DIAGNÓSTICO DE BRECHAS EN MATERIA DE PROTECCIÓN DE DATOS PERSONALES 7

3. PLAN DE IMPLEMENTACIÓN DEL PROGRAMA DE PROTECCIÓN DE DATOS PERSONALES 9

4. GOBIERNO DEL PROGRAMA DE PROTECCIÓN DE DATOS PERSONALES.....14

5. SEGUIMIENTO Y MEJORA CONTINUA DEL PROGRAMA DE PROTECCIÓN DE DATOS PERSONALES 17

6. CRITERIOS DE ÉXITO Y CIERRE DEL PROGRAMA.....19

1. CONTEXTO Y JUSTIFICACIÓN DEL PLAN DE IMPLEMENTACIÓN DEL PROGRAMA DE PROTECCIÓN DE DATOS PERSONALES

1.1. Contexto Normativo y Regulatorio

La protección de datos personales constituye actualmente un elemento fundamental dentro de la gestión de riesgos organizacionales, la seguridad de la información y el cumplimiento regulatorio. En el Ecuador, la Ley Orgánica de Protección de Datos Personales (LOPDP), publicada en el Registro Oficial Suplemento No. 459 de 26 de mayo de 2021, establece el marco jurídico para garantizar el derecho fundamental de las personas a la protección de sus datos personales, regulando el tratamiento de la información en entidades públicas y privadas.

Con la finalización del período de transición establecido en la ley y la posterior emisión del Reglamento General de la LOPDP, las organizaciones que realizan tratamiento de datos personales se encuentran obligadas a implementar medidas jurídicas, organizativas y técnicas que aseguren el cumplimiento de los principios de licitud, lealtad, transparencia, minimización de datos, seguridad, responsabilidad proactiva y protección efectiva de los derechos de los titulares.

En este contexto, las instituciones del sector financiero, debido a la naturaleza de los datos que gestionan (incluyendo información de identificación personal, datos financieros, datos laborales y registros transaccionales), se encuentran dentro de las organizaciones con mayor exposición a riesgos regulatorios, operativos y reputacionales asociados al tratamiento inadecuado de datos personales.

1.2. Situación Actual de la Organización

Como parte del proceso de fortalecimiento del gobierno de la información y del cumplimiento normativo en materia de protección de datos personales, la organización ha iniciado un proceso de diagnóstico preliminar orientado a identificar los tratamientos de datos existentes, los sistemas involucrados, las áreas responsables y los mecanismos actualmente utilizados para la gestión de información personal.

Este proceso ha incluido actividades tales como:

I. Levantamiento inicial de información mediante encuestas dirigidas a las diferentes áreas de la organización
II. Identificación preliminar de procesos que implican tratamiento de datos personales
III. Análisis inicial del estado de cumplimiento frente a los requerimientos establecidos por la LOPDP
IV. Elaboración de informes de seguimiento dentro de las funciones del Delegado de Protección de Datos (DPD).

Los resultados obtenidos evidencian que, si bien existen controles operativos y tecnológicos implementados en diferentes áreas (principalmente en el ámbito de seguridad de la información y gestión de sistemas), la organización aún no cuenta con un programa integral y formalizado de

protección de datos personales, estructurado bajo un enfoque de gobernanza, gestión de riesgos y responsabilidad demostrable (accountability).

Entre las principales observaciones identificadas se encuentran:

- **I.** Ausencia de un Registro de Actividades de Tratamiento (RAT) institucional consolidado,
- **II.** Inexistencia de políticas corporativas específicas en materia de protección de datos personales.
- **III.** Ausencia de procedimientos formalizados para la atención de derechos de los titulares de datos.
- **IV.** Falta de procesos estructurados para la gestión de incidentes o brechas de seguridad relacionadas con datos personales.
- **V.** Necesidad de fortalecer la gestión contractual con terceros que puedan actuar como encargados del tratamiento.

Estas brechas no necesariamente implican un incumplimiento deliberado de la normativa, sino que reflejan un nivel inicial de madurez organizacional en materia de protección de datos, común en organizaciones que se encuentran en fase de implementación de programas de privacidad y protección de datos.

1.3. Enfoque de Gobernanza del Programa de Protección de Datos

La implementación de la protección de datos personales no debe abordarse únicamente desde una perspectiva documental o jurídica, sino como parte de un sistema de gobernanza de la información, en el cual se integran aspectos legales, organizativos, tecnológicos y de gestión de riesgos.

En este sentido, el presente plan adopta un enfoque basado en principios de gobernanza y responsabilidad proactiva, donde la organización no solo busca cumplir formalmente con la normativa vigente, sino demostrar de manera estructurada que gestiona adecuadamente los riesgos asociados al tratamiento de datos personales.

Este enfoque implica:

- **I.** Establecer roles y responsabilidades claras en materia de protección de datos.
- **II.** Documentar y mantener actualizado el registro de actividades de tratamiento.
- **III.** Desarrollar políticas y procedimientos institucionales que regulen el tratamiento de datos.
- **IV.** Implementar controles técnicos y organizativos que aseguren la confidencialidad, integridad, disponibilidad y trazabilidad de los datos personales, incluyendo medidas de cifrado, control de accesos, autenticación multifactor, prevención de pérdida de datos, monitoreo de seguridad y protección de respaldos.
- **V.** Establecer mecanismos de monitoreo, seguimiento y mejora continua del programa de protección de datos.

La ejecución de estas acciones corresponde a las áreas internas competentes y, para garantizar la calidad, objetividad y cumplimiento de plazos, se recomienda la contratación de una empresa

externa especializada en protección de datos personales. El Delegado de Protección de Datos actuará como asesor y supervisor del proceso, verificando la adecuación de los entregables a la normativa vigente, sin asumir responsabilidades operativas de implementación.

Desde la perspectiva de auditoría y cumplimiento, este enfoque permite a la organización demostrar ante organismos de control, auditores internos o externos, y ante la Autoridad de Protección de Datos Personales, que existe un proceso estructurado de implementación y mejora continua del sistema de protección de datos personales.

1.4. Objetivo del Plan de Implementación

El presente Plan de Implementación del Programa de Protección de Datos Personales tiene como objetivo establecer un marco estructurado de acciones orientadas a cerrar las brechas identificadas en el diagnóstico preliminar y avanzar progresivamente hacia el cumplimiento de las disposiciones establecidas en la Ley Orgánica de Protección de Datos Personales y su normativa complementaria.

Para ello, el plan define:

I. Las principales áreas de mejora identificadas.
II. Las acciones necesarias para la implementación del programa de protección de datos.
III. Los responsables institucionales involucrados en su ejecución.
IV. Los plazos estimados para su desarrollo.
V. Los mecanismos de seguimiento y control del avance del programa.

Este documento constituye, por tanto, la hoja de ruta institucional para la implementación progresiva del sistema de protección de datos personales, permitiendo a la organización demostrar un compromiso activo con el cumplimiento normativo, la gestión responsable de la información y la protección de los derechos de los titulares de datos.

1.4.1. Objetivos Específicos del Plan

I. Implementar el Registro de Actividades de Tratamiento (RAT) que documente al menos el 85% de los procesos críticos identificados en el diagnóstico.
II. Contar con la Política Institucional de Protección de Datos Personales y los procedimientos prioritarios (gestión de derechos ARCO, gestión de incidentes, conservación y eliminación) formalizados y aprobados por Gerencia.
III. Establecer la estructura de gobernanza con roles y responsabilidades claramente definidos, incluyendo la definición del modelo de ejecución a través de un proveedor externo especializado.
IV. Implementar las medidas técnicas de seguridad priorizadas en función del análisis de riesgos.
V. Capacitar al menos al 90% del personal que trata datos personales en los principios y obligaciones de la LOPDP.

2. DIAGNÓSTICO DE BRECHAS EN MATERIA DE PROTECCIÓN DE DATOS PERSONALES

2.1. Metodología de Diagnóstico

Con el objetivo de evaluar el nivel de cumplimiento de la organización respecto a las disposiciones establecidas en la Ley Orgánica de Protección de Datos Personales (LOPDP) y su normativa complementaria, se llevó a cabo un proceso de diagnóstico preliminar orientado a identificar el estado actual de las prácticas institucionales relacionadas con el tratamiento de datos personales.

El diagnóstico se desarrolló mediante un enfoque basado en levantamiento de información organizacional y análisis comparativo frente a los requerimientos regulatorios aplicables. Este proceso permitió identificar las brechas existentes entre la situación actual de la organización y las prácticas recomendadas para la implementación de un programa integral de protección de datos personales.

Las actividades realizadas durante esta fase incluyeron:

I. Levantamiento de información mediante encuestas dirigidas a las diferentes áreas organizacionales que realizan tratamiento de datos personales.
II. Identificación preliminar de procesos, sistemas y flujos de información que involucran datos personales.
III. Revisión inicial de controles organizativos y tecnológicos relacionados con la seguridad de la información.
IV. Análisis de la existencia o ausencia de políticas, procedimientos y registros relacionados con la gestión de datos personales.

Este diagnóstico constituye la base para la definición de un plan estructurado de implementación del programa de protección de datos personales, permitiendo priorizar las acciones necesarias para fortalecer el nivel de cumplimiento de la organización. El análisis detallado de cumplimiento frente a las disposiciones de la Ley Orgánica de Protección de Datos Personales y SPDP se presenta en el **Anexo A – Cumplimiento Normativo y Checklist SPDP**, donde se identifica el estado actual de cada componente, los riesgos asociados y las acciones recomendadas para alcanzar el cumplimiento.

2.2. Áreas Evaluadas

El diagnóstico se estructuró considerando los principales componentes que conforman un programa de protección de datos personales bajo un enfoque de gobernanza, gestión de riesgos y responsabilidad demostrable (accountability).

Las áreas evaluadas incluyen:

I. Gobernanza y estructura organizacional en materia de protección de datos.
II. Registro de actividades de tratamiento de datos personales.
III. Políticas y procedimientos institucionales de protección de datos.

IV. Gestión de derechos de los titulares de datos.
V. Gestión de encargados del tratamiento y relaciones contractuales con terceros.
VI. Medidas técnicas y organizativas de seguridad de la información.
VII. Gestión de incidentes y brechas de seguridad relacionadas con datos personales.
VIII. Cultura organizacional y procesos de capacitación en materia de protección de datos.

La evaluación de estas áreas permitió identificar el grado de madurez organizacional en la gestión de datos personales y establecer los elementos que requieren fortalecimiento para alcanzar un nivel adecuado de cumplimiento normativo.

2.3. Principales Brechas Identificadas

A partir del análisis realizado, se identificaron diversas brechas relacionadas con la formalización y estructuración del programa institucional de protección de datos personales.

Entre las principales brechas identificadas se destacan las siguientes:

I. **Registro de Actividades de Tratamiento (RAT). –** La organización no cuenta actualmente con un Registro de Actividades de Tratamiento institucional consolidado que documente de manera estructurada los tratamientos de datos personales realizados por las diferentes áreas.

II. **Políticas institucionales de protección de datos. –** No se dispone de una política corporativa formal que establezca lineamientos institucionales para el tratamiento de datos personales y la protección de la información de los titulares.

III. **Procedimientos para el ejercicio de derechos de los titulares. –** No se han definido procedimientos institucionales formalizados para la gestión de solicitudes relacionadas con los derechos de acceso, rectificación, actualización, oposición o eliminación de datos personales.

IV. **Gestión de encargados del tratamiento. –** Los contratos con proveedores o terceros que podrían tener acceso a datos personales no contemplan de manera sistemática cláusulas específicas relacionadas con la protección de datos personales y las obligaciones del encargado del tratamiento.

V. **Gestión de incidentes y brechas de seguridad. –** No se dispone actualmente de un procedimiento formal que establezca las acciones a seguir ante incidentes o brechas de seguridad que puedan comprometer datos personales.

VI. **Gobierno y supervisión del programa de protección de datos. –** Si bien se han iniciado acciones preliminares de diagnóstico y levantamiento de información, la organización aún no cuenta con un marco institucional formal para la gestión continua del programa de protección de datos personales.

VII. **Medidas técnicas de seguridad no formalizadas. –** Si bien existen controles técnicos básicos implementados en la organización, estos no se encuentran documentados ni integrados dentro de un marco formal de protección de datos personales, evidenciándose la necesidad de implementar medidas específicas como cifrado de bases de datos, autenticación multifactor, prevención de pérdida de datos (DLP), monitoreo de eventos (SIEM) y protección avanzada de respaldos, entre otras.

2.4. Nivel de Madurez Inicial

Con base en los resultados obtenidos durante el diagnóstico preliminar, se puede concluir que la organización se encuentra en una fase inicial de madurez en la implementación del programa de protección de datos personales.

Este escenario es consistente con organizaciones que han iniciado recientemente procesos de alineación normativa frente a la LOPDP y que se encuentran en proceso de estructurar formalmente sus mecanismos de gobernanza, documentación y control en materia de tratamiento de datos personales.

La identificación de estas brechas constituye un paso fundamental para el desarrollo del Plan de Implementación del Programa de Protección de Datos Personales, el cual permitirá establecer acciones concretas orientadas a fortalecer progresivamente el cumplimiento normativo y la gestión responsable de la información. La clasificación y priorización de las brechas identificadas se presenta en el **Anexo B – Matriz de Brechas y Plan de Acción**, el cual constituye la base para la definición del roadmap de implementación del programa.

3. PLAN DE IMPLEMENTACIÓN DEL PROGRAMA DE PROTECCIÓN DE DATOS PERSONALES

3.1. Enfoque de Implementación

Con base en los resultados del diagnóstico preliminar y las brechas identificadas en materia de protección de datos personales, la organización ha definido la implementación progresiva de un Programa Institucional de Protección de Datos Personales, orientado a fortalecer el cumplimiento de la Ley Orgánica de Protección de Datos Personales (LOPDP) y a establecer un sistema de gobernanza adecuado para la gestión de información personal.

La implementación del programa se desarrollará bajo un enfoque progresivo basado en priorización de riesgos, permitiendo estructurar de manera ordenada los elementos organizativos, documentales y técnicos necesarios para la correcta gestión de los datos personales tratados por la institución.

Este enfoque permite a la organización avanzar de manera planificada en la implementación de controles y mecanismos de cumplimiento, priorizando inicialmente aquellos elementos fundamentales que constituyen la base del sistema de gestión de protección de datos personales.

La construcción del Registro de Actividades de Tratamiento, la definición de políticas y procedimientos, y la implementación de mecanismos de gestión de incidentes serán desarrolladas por las áreas institucionales competentes, con el apoyo de un proveedor externo especializado en protección de datos personales, cuya contratación se recomienda para garantizar la calidad, objetividad y cumplimiento de plazos. El Delegado de Protección de Datos supervisará el cumplimiento de las actividades y verificará la adecuación de los entregables a la normativa vigente, sin asumir funciones operativas.

Este modelo de implementación permite a la organización demostrar un proceso estructurado de cumplimiento normativo, alineado con los principios de responsabilidad proactiva (accountability) establecidos en la normativa vigente.

3.2. Ejes del Programa de Protección de Datos

El programa institucional de protección de datos personales se estructura en torno a los siguientes ejes de implementación:

Gobernanza de Protección de Datos

Este eje contempla la definición de la estructura organizativa necesaria para la gestión del programa de protección de datos personales dentro de la organización.

Incluye elementos tales como:

- **I.** Definición de roles y responsabilidades institucionales en materia de protección de datos.
- **II.** Formalización del rol del delegado de protección de datos.
- **III.** Establecimiento de mecanismos de coordinación con las diferentes áreas organizacionales.

La correcta definición de estos elementos permite establecer un marco claro de responsabilidades para la gestión del tratamiento de datos personales dentro de la organización.

La definición de roles y responsabilidades será formalizada mediante acto resolutivo de la Gerencia General. El Delegado de Protección de Datos asesorará en la definición de estos roles, pero no asumirá funciones operativas.

Registro de Actividades de Tratamiento de Datos Personales

El Registro de Actividades de Tratamiento (RAT) constituye el elemento central del programa de protección de datos personales, ya que permite identificar, documentar y mantener actualizados los tratamientos de datos personales realizados por la organización.

Este registro permitirá documentar, entre otros aspectos:

- **I.** La finalidad de los tratamientos de datos personales.
- **II.** Las categorías de datos tratados.
- **III.** Las categorías de titulares de datos.
- **IV.** Los responsables y encargados del tratamiento.
- **V.** Los plazos de conservación de los datos.
- **VI.** Las medidas de seguridad implementadas.

El desarrollo progresivo del RAT permitirá a la organización contar con una visión integral de los tratamientos de datos personales realizados en sus procesos institucionales.

Políticas y Procedimientos Institucionales

Este eje contempla el desarrollo de la documentación normativa necesaria para regular el tratamiento de datos personales dentro de la organización.

Entre los documentos previstos se encuentran:

- **I.** Política institucional de protección de datos personales.
- **II.** Procedimiento para la gestión de derechos de los titulares.
- **III.** Procedimiento de gestión de incidentes o brechas de seguridad relacionadas con datos personales.
- **IV.** Procedimiento de conservación y eliminación de datos personales.

Estos documentos permitirán establecer reglas claras para el tratamiento adecuado de la información personal dentro de la organización.

Gestión de Riesgos en Protección de Datos

El programa contempla el desarrollo progresivo de mecanismos de identificación y evaluación de riesgos asociados al tratamiento de datos personales.

Esto permitirá:

- **I.** Identificar posibles escenarios de riesgo relacionados con la seguridad de la información.
- **II.** Evaluar el impacto potencial sobre los titulares de datos.
- **III.** Definir medidas técnicas y organizativas adecuadas para mitigar dichos riesgos.

La gestión de riesgos constituye un elemento clave para garantizar la protección efectiva de los datos personales.

Cultura Organizacional y Capacitación

La implementación del programa de protección de datos requiere fortalecer la cultura organizacional en materia de privacidad y protección de información personal.

Para ello se contempla la realización de actividades de sensibilización y capacitación dirigidas al personal de la organización, con el objetivo de:

- **I.** Promover buenas prácticas en el tratamiento de datos personales.
- **II.** Fortalecer el conocimiento institucional sobre las obligaciones establecidas en la normativa vigente.
- **III.** Reducir los riesgos asociados al manejo inadecuado de la información.

Seguridad Técnica de los Datos Personales

Este eje contempla la implementación progresiva de medidas técnicas de seguridad que garanticen la confidencialidad, integridad, disponibilidad y trazabilidad de los datos personales tratados por la organización.

El alcance de estas medidas será definido de manera progresiva de acuerdo a la asignación de recursos por parte de gerencia para el presente programa. Entre las medidas que se priorizarán, en función del nivel de riesgo y criticidad de los sistemas, se incluyen:

I. **Cifrado y protección de bases de datos:** Cifrado de datos sensibles y crediticios, y controles específicos sobre bases de datos (firewall de base de datos).
II. **Control de accesos y autenticación:** Autenticación multifactor (MFA), políticas de contraseñas, gestión de credenciales y control de accesos basado en directorio activo.
III. **Monitoreo y prevención de pérdida de datos:** Herramientas de prevención de pérdida de datos (DLP) y plataformas de monitoreo de eventos (SIEM).
IV. **Respaldo avanzado y anonimización:** Protección de respaldos (respaldo inmutable) y técnicas de anonimización/seudonimización para entornos de prueba y análisis.
V. **Gestión de consentimientos:** Mecanismos para registrar, almacenar y gestionar de manera auditable los consentimientos otorgados por los titulares.

La implementación de estas medidas será coordinada por las áreas de TI y Seguridad de la Información, con el apoyo de herramientas internas (incluyendo soluciones open source cuando sea técnicamente viable) y, de ser requerido, con el acompañamiento de un proveedor externo especializado. El Delegado de Protección de Datos supervisará la adecuación de las medidas a la normativa vigente.

3.3. Priorización de Acciones

Con el fin de facilitar la implementación progresiva del programa de protección de datos personales, las acciones identificadas se han organizado en función de su nivel de prioridad y del impacto que tienen en el fortalecimiento del cumplimiento normativo.

Las acciones que se describen a continuación constituyen una recomendación técnica del Delegado de Protección de Datos, basada en el diagnóstico institucional y en los plazos regulatorios. La implementación definitiva estará sujeta a la decisión de Gerencia sobre la asignación de recursos y la estrategia de ejecución.

Acciones de Prioridad Alta

I. **Contratación del servicio externo especializado:** La Gerencia General liderará la elaboración de términos de selección y contratación de una empresa con experiencia en implementación de programas de protección de datos personales. Esta empresa será la encargada de desarrollar los entregables técnicos, documentales y de seguridad bajo la supervisión del Delegado de Protección de Datos. (Plazo máximo: XX/XX/XXXX)
II. **Construcción del Registro de Actividades de Tratamiento (RAT):** Esta actividad será ejecutada por el proveedor externo, en coordinación con las áreas internas (Crédito,

Operaciones, TI, Talento Humano, etc.). El DPD supervisará la calidad y adecuación normativa del inventario institucional de tratamientos de datos personales.

III. **Elaboración de la Política Institucional de Protección de Datos Personales:** El documento marco será elaborado por el proveedor externo, con validación del DPD y las áreas de Cumplimiento y Jurídico.

IV. **Desarrollo del procedimiento de gestión de incidentes o brechas de seguridad:** Esta acción será desarrollada por el proveedor externo, en coordinación con las áreas de TI y Seguridad de la Información con asesoría del DPD, bajo supervisión de este último para garantizar el cumplimiento normativo.

V. **Formalización de roles y responsabilidades:** El Delegado de Protección de Datos, junto con asesoría legal, elaborará la propuesta técnica para la resolución de Gerencia que formalice los roles y responsabilidades institucionales en materia de protección de datos.

Acciones de Prioridad Media

I. **Desarrollo del procedimiento institucional para la atención de derechos ARCO de los titulares de datos:** El procedimiento será elaborado por el proveedor externo, y validado por las áreas de Cumplimiento y Jurídico con apoyo técnico del DPD, quien supervisará su adecuación normativa.

II. **Elaboración del procedimiento de conservación y eliminación de datos personales**: Esta acción será desarrollada por el proveedor externo y validado por el DPD, bajo supervisión de este último.

III. **Revisión de contratos con proveedores (encargados del tratamiento):** El proveedor externo, revisará los contratos existentes y propondrá cláusulas base para futuras contrataciones , con asesoría técnica del DPD y validación del área Jurídico. Las áreas internas implementarán las modificaciones necesarias.

Acciones de Prioridad Complementaria

I. **Implementación de medidas técnicas de seguridad:** Las medidas técnicas priorizadas (cifrado, MFA, DLP, SIEM, respaldo inmutable, etc.) serán implementadas por el proveedor externo, en caso de contratación, o por las áreas de TI y Seguridad de la Información con herramientas internas (incluyendo soluciones open source cuando sea viable). Cuando existan soluciones open source viables, podrán ser implementadas directamente por el área de TI; en caso contrario, se considerará la contratación de servicios especializados según el alcance definido. El DPD supervisará la alineación de las medidas con la normativa vigente

II. **Desarrollo del programa institucional de capacitación en materia de protección de datos personales:** El proveedor externo se encargará de impartir la capacitación al personal como parte del programa contratado. El área de Talento Humano brindará apoyo logístico (convocatoria, inscripciones, registro de asistencia) en caso de requerirse. El DPD supervisará la calidad y pertinencia de los contenidos y podrá participar en las sesiones si se estima necesario.

III. **Implementación de mecanismos de evaluación de riesgos asociados al tratamiento de datos personales:** La metodología será desarrollada por el proveedor externo. El área de Riesgos aplicará la metodología, y el DPD supervisará su correcta implementación.

Nota. *La asignación de responsables para la ejecución de las acciones definidas dependerá de la decisión de Gerencia respecto a la contratación de un proveedor externo especializado y la designación de personal interno. En todos los casos, el Delegado de Protección de Datos Personales actúa en calidad de supervisor y asesor, sin asumir funciones operativas de implementación.*

3.4. Cronograma General de Implementación

El proceso de implementación del programa de protección de datos personales se desarrollará de manera progresiva durante el periodo de implementación definido por la organización, priorizando inicialmente los elementos fundamentales del sistema de cumplimiento.

Las primeras fases del proceso estarán orientadas a la construcción del Registro de Actividades de Tratamiento, el desarrollo de la documentación normativa institucional y la definición de la estructura organizativa necesaria para la gestión del programa de protección de datos.

Posteriormente, se desarrollarán las fases relacionadas con la gestión de riesgos, fortalecimiento de controles técnicos, organizativos y consolidación de la cultura institucional en materia de protección de datos.

Se recomienda que la ejecución del programa sea desarrollada por una empresa externa especializada en protección de datos personales, bajo la supervisión del Delegado de Protección de Datos, en razón de que su experiencia, metodología probada y recursos especializados permitirán una implementación más eficiente, ordenada y alineada con los estándares de cumplimiento normativo.

En caso de optar por la contratación externa, el proveedor seleccionado presentará su propio plan de trabajo (roadmap) detallado con hitos, entregables, responsables y plazos específicos, el cual será validado por el DPD y aprobado por Gerencia.

En el escenario de que la implementación sea ejecutada directamente por personal interno, el DPD apoyará con la definición de un cronograma base orientativo, el cual será detallado en el **Anexo C – Roadmap de Implementación del Programa de Protección de Datos Personales**.

Este enfoque permitirá avanzar de manera ordenada en la implementación del programa, asegurando la adecuada articulación entre las diferentes áreas organizacionales y facilitando el seguimiento de los avances del proceso.

4. GOBIERNO DEL PROGRAMA DE PROTECCIÓN DE DATOS PERSONALES

4.1. Estructura de Gobernanza

La implementación del Programa de Protección de Datos Personales requiere la definición de una estructura organizativa que permita gestionar de manera adecuada los tratamientos de

datos personales realizados por la organización, garantizando la asignación clara de responsabilidades y el establecimiento de mecanismos de supervisión y control.

En este sentido, la organización adopta un modelo de gobernanza basado en la distribución de responsabilidades entre las diferentes áreas institucionales que participan en el tratamiento de datos personales, permitiendo asegurar una gestión coordinada y alineada con las disposiciones establecidas en la Ley Orgánica de Protección de Datos Personales.

Este modelo contempla la participación de los siguientes actores institucionales:

I. Responsable del tratamiento.
II. Delegado de Protección de Datos Personales.
III. Áreas operativas que realizan tratamientos de datos.
IV. Área de Tecnologías de la Información.
V. Área de Seguridad de la Información.
VI. Áreas de control institucional.

La correcta articulación entre estos actores permitirá asegurar la implementación progresiva del programa de protección de datos personales y el cumplimiento de las obligaciones establecidas en la normativa vigente.

4.2. Responsable del Tratamiento

El Responsable del Tratamiento corresponde a la organización que determina los fines y medios del tratamiento de los datos personales.

En el caso de la institución, el responsable del tratamiento es el Banco Demo S.A, representada por su máxima autoridad administrativa, Gerente general, quien tiene la responsabilidad de asegurar que el tratamiento de los datos personales se realice de conformidad con la normativa aplicable.

Entre sus principales responsabilidades se encuentran:

I. Garantizar el cumplimiento de la normativa vigente en materia de protección de datos personales.
II. Aprobar las políticas institucionales relacionadas con el tratamiento de datos personales.
III. Facilitar los recursos necesarios para la implementación del programa de protección de datos personales.
IV. Supervisar el desarrollo del plan de implementación y las acciones asociadas al cumplimiento normativo.

La alta dirección cumple un rol fundamental en la consolidación del programa de protección de datos personales, ya que su respaldo institucional permite asegurar la adopción de medidas organizativas adecuadas para la gestión responsable de la información.

4.3. Delegado de Protección de Datos Personales

El Delegado de Protección de Datos Personales (DPD) actúa como la figura encargada de supervisar el cumplimiento de las disposiciones establecidas en la normativa de protección de datos personales dentro de la organización.

Sus funciones incluyen:

- **I.** Asesorar a la organización en materia de protección de datos personales.
- **II.** Supervisar la implementación del programa institucional de protección de datos.
- **III.** Coordinar el proceso de identificación y registro de actividades de tratamiento de datos personales.
- **IV.** Promover la adopción de buenas prácticas en el tratamiento de datos personales.
- **V.** Apoyar en la gestión de incidentes relacionados con la seguridad de los datos personales.
- **VI.** Servir como punto de contacto institucional en materia de protección de datos.

El Delegado de Protección de Datos cumple un rol de supervisión y asesoramiento, contribuyendo al fortalecimiento del sistema institucional de protección de datos personales.

4.4. Responsabilidades de las Áreas Organizacionales

Las diferentes áreas organizacionales que participan en el tratamiento de datos personales tienen la responsabilidad de asegurar que las actividades realizadas dentro de sus procesos cumplan con las disposiciones establecidas en la normativa vigente.

Entre sus responsabilidades se incluyen:

- **I.** Identificar los tratamientos de datos personales asociados a sus procesos operativos.
- **II.** Proporcionar la información necesaria para la construcción y actualización del Registro de Actividades de Tratamiento.
- **III.** Implementar las medidas organizativas y técnicas definidas para la protección de los datos personales.
- **IV.** Colaborar en la gestión de incidentes relacionados con la seguridad de los datos personales.

La participación activa de las áreas operativas resulta fundamental para asegurar la correcta implementación del programa de protección de datos personales.

4.5. Coordinación con área de TI y Seguridad de la Información

La gestión de la protección de datos personales requiere una coordinación estrecha con las áreas responsables de la seguridad de la información y de la infraestructura tecnológica de la organización.

En este sentido, el área de Tecnologías de la Información y el área de Seguridad de la Información participan en el programa de protección de datos personales mediante:

- **I.** Implementación de controles técnicos de seguridad para la protección de la información.
- **II.** Gestión de accesos a los sistemas que almacenan o procesan datos personales.

III. Implementación de mecanismos de monitoreo y registro de actividades en sistemas informáticos.
IV. Apoyo en la gestión de incidentes de seguridad que puedan afectar datos personales.

La articulación entre privacidad y seguridad de la información permite fortalecer la protección de los datos personales desde una perspectiva integral.

4.6. Seguimiento y Supervisión del Programa

Con el fin de asegurar la correcta implementación del programa de protección de datos personales, se establecerán mecanismos de seguimiento y supervisión que permitan evaluar periódicamente el avance de las acciones definidas en el plan de implementación.

Entre los mecanismos de seguimiento previstos se encuentran:

I. Elaboración de informes periódicos de avance del programa de protección de datos personales.
II. Revisión del estado de implementación de las acciones definidas en el plan de implementación.
III. Actualización progresiva del Registro de Actividades de Tratamiento de Datos Personales.
IV. Identificación de nuevas necesidades de mejora o fortalecimiento del programa.

Estos mecanismos permitirán mantener un proceso continuo de mejora en la gestión de la protección de datos personales dentro de la organización.

4.7. Modelo de Ejecución del Programa

La ejecución operativa del programa estará a cargo de una empresa externa especializada que se contrate para el efecto, bajo la supervisión técnica del Delegado de Protección de Datos Personales (DPD). Esta empresa será responsable de desarrollar los entregables técnicos y documentales (Registro de Actividades de Tratamiento, políticas, procedimientos, evaluaciones de impacto, etc.), de acuerdo con el cronograma y la metodología que se definan en el contrato.

La Gerencia General, o el responsable que esta designe, facilitará la coordinación con las áreas internas, garantizando el acceso a la información requerida y apoyando la convocatoria a las áreas operativas cuando sea necesario para el cumplimiento de las actividades previstas.

El Delegado de Protección de Datos Personales mantiene su rol independiente de supervisión, asesoría y verificación del cumplimiento normativo, sin asumir funciones de coordinación operativa. Los informes del proveedor (ejecución) y del DPD (supervisión) son complementarios.

5. SEGUIMIENTO Y MEJORA CONTINUA DEL PROGRAMA DE PROTECCIÓN DE DATOS PERSONALES

5.1. Monitoreo del Programa de Protección de Datos

Con el fin de asegurar la correcta implementación del Programa de Protección de Datos Personales, la organización establecerá mecanismos de monitoreo orientados a evaluar periódicamente el avance de las acciones definidas en el plan de implementación.

El monitoreo del programa permitirá verificar el nivel de cumplimiento de las actividades planificadas, identificar posibles desviaciones y adoptar las medidas correctivas necesarias para fortalecer la gestión institucional de los datos personales.

El seguimiento operativo del programa será coordinado por la empresa externa especializada, en coordinación con la Gerencia o el responsable que esta designe.

5.2. Indicadores de Seguimiento

Como parte del proceso de monitoreo del programa de protección de datos personales, se establecerán indicadores que permitan evaluar el progreso de las actividades relacionadas con la implementación del sistema de cumplimiento institucional.

Entre los indicadores que podrán utilizarse para el seguimiento del programa se incluyen:

I. Porcentaje de tratamientos de datos personales identificados y registrados en el Registro de Actividades de Tratamiento.
II. Número de documentos normativos desarrollados en materia de protección de datos personales.
III. Número de áreas institucionales que han participado en el proceso de levantamiento de información.
IV. Número de procesos institucionales incorporados al Registro de Actividades de Tratamiento.
V. Número de actividades de capacitación realizadas en materia de protección de datos personales.

Estos indicadores serán reportados periódicamente por la empresa externa especializada a la Gerencia, con validación técnica del Delegado de Protección de Datos en cuanto a su pertinencia y alineación con los requisitos normativos.

5.3. Actualización del Registro de Actividades de Tratamiento

El Registro de Actividades de Tratamiento de Datos Personales constituye un instrumento dinámico que debe mantenerse actualizado conforme evolucionen los procesos organizacionales que impliquen tratamiento de datos personales.

Por esta razón, se establecerán mecanismos que permitan asegurar la actualización periódica del registro, considerando aspectos tales como:

I. Incorporación de nuevos tratamientos de datos personales.
II. Modificación de procesos existentes que impliquen cambios en el tratamiento de datos.
III. Incorporación de nuevos sistemas o herramientas tecnológicas que procesen datos personales.

IV. Actualización de medidas de seguridad implementadas.

La actualización del registro será responsabilidad de las áreas operativa. El Delegado de Protección de Datos supervisará que la información registrada sea completa, exacta y esté alineada con la normativa vigente.

5.4. Mejora Continua del Programa

La gestión de la protección de datos personales debe desarrollarse bajo un enfoque de mejora continua, permitiendo fortalecer progresivamente los controles organizativos y técnicos implementados por la organización.

Este proceso de mejora continua permitirá:

I. Identificar oportunidades de fortalecimiento del programa de protección de datos.
II. Incorporar nuevas prácticas o controles que permitan mejorar la gestión de los datos personales.
III. Adaptar el programa institucional a cambios regulatorios o tecnológicos.

La empresa externa especializada coordinará la ejecución de las acciones de mejora definidas, mientras que el Delegado de Protección de Datos supervisará que dichas acciones se ejecuten en cumplimiento de los estándares normativos aplicables.

5.5. Preparación para Procesos de Auditoría o Supervisión

La implementación del Programa de Protección de Datos Personales permitirá a la organización contar con evidencia documentada del proceso de gestión institucional de los datos personales, facilitando la atención de procesos eventuales de auditoría interna o revisiones por parte de organismos de control.

Entre los elementos que permitirán demostrar el nivel de avance del programa se encuentran:

I. El presente Plan de Implementación del Programa de Protección de Datos Personales.
II. El Registro de Actividades de Tratamiento de Datos Personales.
III. Las políticas y procedimientos institucionales desarrollados.
IV. Los informes periódicos de seguimiento elaborados por la empresa externa especializada (informe de ejecución).
V. Los informes de supervisión y recomendaciones emitidos por el Delegado de Protección de Datos Personales.
VI. La documentación relacionada con actividades de capacitación y sensibilización.

La disponibilidad de estos elementos permitirá demostrar la existencia de un proceso estructurado de cumplimiento normativo y gestión responsable del tratamiento de datos personales dentro de la organización.

6. CRITERIOS DE ÉXITO Y CIERRE DEL PROGRAMA

Se considerará que el Programa de Protección de Datos Personales ha alcanzado su fase de implementación inicial cuando se cumplan los siguientes criterios:

I. El Registro de Actividades de Tratamiento (RAT) se encuentra documentado y aprobado por las áreas responsables.

II. La Política Institucional de Protección de Datos Personales y los procedimientos prioritarios están formalizados y comunicados al personal.

III. La estructura de gobernanza está definida mediante acto resolutivo de Gerencia, con roles y responsabilidades asignados.

IV. Se ha realizado al menos una ronda de capacitación al personal crítico.

V. El plan de trabajo del proveedor externo o el cronograma interno ha sido ejecutado conforme a lo planificado.

Una vez cumplidos estos criterios, el programa entrará en una fase de operación y mejora continua, donde el seguimiento periódico (informes de la empresa externa especializada y del DPD) garantizará la sostenibilidad del cumplimiento.

Nota. *Este documento es una versión anonimizada con fines demostrativos. No representa un compromiso legal de ninguna entidad real. Todos los nombres de instituciones, personas y fechas específicas han sido reemplazados por referencias genéricas o ficticias.*